README

团队知识工程

> 面向 40 人业务团队的知识与 Skill 双资产 AI 工作台，并沿着受控 Plugin 管理持续演进：让业务人员把资料和任务经验沉淀为可治理、可运行、可复用、可复核的团队能力。

当前状态

当前处于 **P0：双资产边界与能力侦察**。本项目不是只做 WeKnora 知识库，而是同时建设两条资产生产线，并让它们汇合到 Agent 运行：

```
知识生产线：资料 → 知识草稿 → 确认/审核 → Git/CI → WeKnora → 可引用知识
Skill 生产线：任务需求 → Skill 草稿 → 契约/权限/测试 → Git/CI → 发布/装载 → 可运行 Skill

知识版本 + Skill digest + profile
  → Agent 运行
  → 结果/反馈/业务结果
  → 知识复核或 Skill 回归

治理闭环与分发闭环分开：
- 治理闭环决定什么可以成为正式知识、Skill 或后续 Plugin；
- 分发闭环决定已批准版本如何安全到达目标 dsh/profile，并能读回、回滚和审计。
```

长期演进为三个独立资产域：

```
Knowledge：Agent 应该知道什么
Skill：Agent 应该如何完成一类任务
Plugin：平台或 Agent 可以调用哪些受控外部能力

Skill 组合 Plugin 提供的工具完成任务；Plugin 不等于 Skill。
```

第一步只建设知识 + Skill：先跑通双资产创建、治理、装载、运行和反馈闭环；待双资产稳定并出现外部系统复用、集中权限/凭据或运行时隔离需求后，再扩展 Plugin 管理。

未经过目标环境验证的 DSH、WeKnora、SkillHub、DeepSeek Bot、Console 或 Gateway 能力，均不得视为已经集成。

如何阅读

按产品和落地顺序阅读：

1. [方案总览与关键决策](./方案/00-方案总览与关键决策.md)
2. [问题、用户与产品范围](./方案/01-问题、用户与产品范围.md)
3. [端到端双资产工作流](./方案/02-端到端知识工作流.md)
4. [知识与 Skill 资产模型](./方案/03-知识资产与生命周期.md)
5. [角色、治理与运营机制](./方案/04-角色、治理与运营机制.md)
6. [系统架构与权威边界](./方案/05-系统架构与权威边界.md)
7. [数据、状态与可追溯性](./方案/06-数据、状态与可追溯性.md)
8. [发布、安全与故障处置](./方案/07-发布、安全与故障处置.md)
9. [MVP 实施、验证与验收](./方案/08-MVP实施、验证与验收.md)

外部平台事实和源码评估放在[验证材料](./验证/README.md)，不能反过来定义产品目标。

核心判断

- 这是知识和 Skill 的双资产工作台，不是只有知识检索的系统。
- **知识**回答 Agent“应该知道什么”；**Skill**回答 Agent“应该如何完成一类任务”。
- Git 是知识源文件、Skill 源码、契约、测试、metadata 和评审的 canonical source。
- WeKnora 只负责已批准知识的索引、权限过滤和检索；它不能替代 Skill 管理。
- Skill/Agent 分发由已验证的 SkillHub、TeamAI distribution adapter 或管理员流程承担；TeamAI 负责 Git-based 初始化、同步、版本切换和本地 dsh 注入，但不负责事实审批、Skill 质量、知识检索或 Plugin runtime。
- DSH 负责 profile、Skill 装载、工具调用、人工确认和运行结果。
- Plugin 是长期演进的独立资产域，负责受控工具/外部系统能力的 manifest、权限、安装、健康和运行时治理；它不替代 Skill 管理。
- 模型负责提取、摘要、分类、起草和发现冲突；脚本负责 schema、权限、依赖、secret 和回归门禁；人负责事实、范围、风险和发布责任。
- 先用模块化单体 + 持久化 worker；Console/Gateway/Plugin runtime/多 provider 是演进形态，不是双资产目标的替代品。

当前阶段状态

- **已决定**：双资产产品边界、知识/Skill 关系、Git/WeKnora/SkillHub/DSH 权责、人工控制点和阶段顺序；分发层与治理层分离，TeamAI 是可替换的分发适配层候选；Plugin 是长期独立资产域，不进入首期硬依赖。
- **待验证**：目标版本的 DSH loader/profile、SkillHub API、TeamAI CLI/repository/hooks/local injection、WeKnora 索引状态、Plugin/tool 扩展、权限/凭据和 Bot 适配。
- **延后**：多租户、完整 Gateway、完整 Plugin Registry/Runtime、MCP 高风险工具、跨团队数字员工、Bot 协作和生产写入；不是延后 Skill 管理。
- **禁止**：模型直接发布知识或 Skill、Agent 直接 push/merge `main`、Skill 自行扩大权限、把 Bot Memory 当正式资产。

与其他项目的边界

`项目/SPC-DeepSeek-Harness/` 是验证 DSH/Agent 平台能力的业务试点；本项目沉淀可复用的知识与 Skill 双资产方法。

`研究/产品/Agent资产与团队治理/` 记录外部产品事实和横向选型；本项目记录团队自己的决策、验证和实施结果。

维护规则

- 方案目录回答“目标是什么、如何运行、如何治理和如何落地”；验证目录回答“外部能力实际证明了什么”。
- 每个关键决策只有一个权威位置；其他文档通过链接引用，不重复改写。
- 知识、Skill、运行和发布状态都必须有证据；超时、回调丢失和状态未知不能展示为成功。
- 不提交生产 Token、Cookie、密码、业务原文或个人敏感信息。

00-方案总览与关键决策

方案总览与关键决策

> 本文是方案的唯一决策摘要。它定义产品目标、双资产范围、当前架构和阶段；具体流程、资产、治理、实现与验收见后续文档。

1. 产品定义

这是一个面向 40 人业务团队的**知识与 Skill 双资产 AI 工作台**，并沿着受控 Plugin 管理持续演进。它不是单独的聊天机器人、向量数据库或企业 Agent 平台。

它持续完成两件事：

- 把资料、会议、复盘和业务规则变成有来源、有人负责、可检索、可复核的知识；
- 把高频、低风险、可重复的业务任务变成有契约、可测试、可授权、可发布、可回滚的 Skill。

```
知识：Agent 应该知道什么
Skill：Agent 应该如何完成一类任务
Plugin：平台或 Agent 可以调用哪些受控外部能力
工作台：让三类资产被创建、治理、装载、运行和持续改进
```

知识、Skill、Plugin 是三个独立资产域：Skill 可以组合 Plugin 提供的工具完成任务，一个 Plugin 也可以被多个 Skill 复用；Plugin 提供运行时能力，不等于 Skill。第一阶段只建设知识 + Skill，Plugin 管理在双资产稳定并出现明确触发条件后扩展。

2. 首期要同时证明两条链

选择一个低风险知识域和一个低风险高频任务，服务 5–8 名真实使用者：

```
知识链：资料 → 候选知识 → 事实/范围确认 → Git/MR → WeKnora → 带来源的检索
Skill 链：任务需求 → Skill 草稿 → 契约/权限/effects → 测试回归 → Git/MR → 非生产 profile 装载

分发链（首期可人工，后续自动化）：
批准版本 → package/digest → SkillHub、TeamAI 或管理员流程
  → 目标 dsh/profile 安装 → 版本读回 → Agent 运行

知识版本 + Skill digest + profile
  → DSH Agent 运行
  → 结果/人工纠正/业务结果
  → 知识复核或 Skill 回归任务
```

首期限制的是 Skill 的风险和环境，不是取消 Skill 管理，也不是强制引入 TeamAI。TeamAI 不能用时，Git/CI + 管理员发布 + DSH 非生产 profile 必须完成闭环。

3. 核心决策

| 决策 | 当前结论 |

|---|---|

| 产品边界 | 知识资产管理、Skill 资产管理和 Agent 运行反馈 |

| 正式源 | Git + MR/CI + 人工审核 |

| 知识检索 | WeKnora，只接收已批准知识 |

| Skill 注册/分发 | SkillHub、TeamAI distribution adapter（均需验证）或管理员流程；首期支持固定 package/digest、profile、审批和回滚，自动分发可后置 |

| TeamAI 定位 | 可替换的团队 AI 资产分发/本地同步层：init、pull、push 到变更分支、版本切换和 dsh 注入；不是 canonical source、审批系统或运行时 |

| Plugin 管理 | 独立 Plugin catalog/registry/runtime（后续）；首期不做开放市场，先预留 manifest、权限和运行归因接口 |

| Skill 执行 | DSH profile、loader、工具策略和人工确认；Skill 组合受控工具完成任务 |

| 首期控制面 | 模块化单体 + 数据库任务表 + worker |

| 业务体验 | 业务人员提交、确认、审核、查询、反馈；不直接操作 Git |

| 首期 Skill | 一个低风险 Skill，完成创建、契约、测试、审核、非生产装载、运行和反馈 |

| Bot | 可选 Agent 协作层，不是资产治理权威 |

| 高风险动作 | 人工 gate、最小权限、真实状态读回、审计和回滚 |

4. 四条不可破坏的原则

1. **双资产、一套治理底座**：知识和 Skill 都有 owner、版本、来源、审核、权限、反馈和回滚，但两者不能混成一种资产；Plugin 作为后续第三类资产接入同一治理底座，也保留独立权限和生命周期。

2. **一类对象一个权威写入面**：Git 保存知识、Skill、Agent Manifest 和受控分发配置的正式源；WeKnora 做知识索引；SkillHub/TeamAI 只分发已批准版本；DSH 做运行。

3. **状态必须有证据**：请求发出、HTTP 200、模型说完成，都不等于业务成功。

4. **自动化降低成本，不替代责任**：模型起草，脚本门禁，人确认事实、范围、风险和发布责任。

5. 阶段顺序

| 阶段 | 要证明的结果 | 进入条件 |

|---|---|---|

| P0 | 双资产模型、关系、样本、角色、schema、provider contract、分发 contract 和运行关联清楚 | 开始真实集成前 |

| P1 | 一个知识闭环 + 一个低风险 Skill 闭环可创建、审核、装载和运行；TeamAI 可选，不可用不阻塞 | P0 证据齐全 |

| P2 | 知识和 Skill 的运行反馈、质量报告和复核运营持续运行 | P1 有真实使用 |

| P3 | SkillHub/TeamAI/管理员流程中至少一种分发路径具备固定版本、安装读回、灰度、审计和回滚 | P1/P2 稳定 |

| P4 | 双资产稳定后，按触发证据建设受控 Plugin 管理：一个低风险适配器、manifest、权限、安装/启停、health 和回滚 | 出现第二外部系统、跨 Skill 复用或集中权限/凭据需求 |

| P5 | 开放 Plugin/MCP/Marketplace、多租户和高风险生产写入 | P4 有真实价值且安全、隔离、审批和回滚证据齐全 |

阶段由退出证据推进，不按日历自动升级。

6. 成功标准

MVP 退出时：

- 非程序员不操作 Git 也能创建知识草稿和 Skill 草稿；
- 正式知识有 owner、来源、适用范围、版本和复核日期；
- Skill 有 owner、输入/输出契约、知识依赖、权限/effects、测试和固定版本；
- 知识检索返回来源和版本，Skill 运行能反查 digest、profile 和 Git commit；
- 反馈能分别进入知识复核或 Skill 回归；
- 发布、分发、装载、运行和回滚均有审计和人工接管路径；未审核版本不能因自动同步直接生效；
- 至少有一个真实任务减少重复劳动或返工。

北极星指标是：**有引用且由固定 Skill 可靠完成的有效任务次数**。

01-问题、用户与产品范围

问题、用户与产品范围

1. 业务问题

团队不只是缺少知识，也缺少把知识稳定转成 Agent 能力的机制；长期还需要把外部系统和工具能力变成受控、可复用的 Plugin：

- 资料、会议、复盘和规则散落，内容无法持续维护；
- Agent 能回答问题，却不一定能说明依据、版本和适用范围；
- 同一类任务反复依赖个人经验和临时 Prompt，无法复用；
- Skill 没有输入输出契约、权限边界、测试和版本，运行结果不可控；
- 外部系统接入依赖临时脚本，权限、凭据、兼容性和故障责任不清；
- 多人本地 dsh 的 Skill/Rule/Agent 配置容易版本不一致，新人接入和回滚依赖手工操作；
- 跨团队共享 Agent 或 Skill 时重复建设，经验难以稳定分发；
- 反馈不能判断应该修知识、修 Skill、修 Plugin/权限、修分发还是修流程；
- 一开始建设大平台，复杂度超过团队维护能力。

因此目标是**让业务知识变成可引用资产，让高频任务变成可运行 Skill**。

2. 用户与责任

| 角色 | 主要动作 | 负责什么 |

|---|---|---|

| 贡献者 | 提交资料、提出任务、确认草稿、反馈结果 | 输入事实和业务需求 |

| 领域 steward | 确认知识事实、范围、例外和复核周期 | 知识正确性 |

| Skill owner | 定义任务边界、契约、测试、依赖和预期结果 | Skill 行为和质量 |

| 审核人 | 审核跨域、敏感、高风险知识或 Skill | 发布责任 |

| 平台 owner | 维护模板、门禁、profile、权限、发布、故障和 coding agent | 平台可靠性 |

| Distribution/platform owner | 维护 Skill/Agent 分发适配器、目标 workspace、同步、版本切换和安装读回 | 分发可靠性和版本一致性 |

| Plugin/integration owner | 维护外部系统适配器、tool manifest、权限/凭据和兼容性 | Plugin 运行质量和供应商变化 |

| 使用者 | 查询知识、选择 Skill、确认结果、报告问题 | 使用效果和反馈 |

早期平台 owner 可以只有 1 人，但每个知识域至少有 steward/备份 steward，每个生产 Skill 必须有 owner/backup owner。

3. 首期核心场景

选择一个“低风险、频繁发生、结果可回放”的任务，例如：

- 研究资料初筛：Skill 检索已批准知识，整理来源和证据卡片；

- 流程规则检查：Skill 根据业务输入和知识规则生成检查结果；
- 项目复盘整理：Skill 把复盘材料整理成知识候选和行动项。

场景选择必须写清输入、知识依赖、Skill 产出、使用者、失败代价、人工 gate 和 fallback。

4. MVP 必须有

知识能力

- 收件箱和知识卡片；
- 来源、证据、适用范围和复核日期；
- Git/CI 变更包、审核和回滚；
- WeKnora 索引、ACL、来源和版本引用；
- 反馈和复核任务。

Skill 能力

- Skill 需求登记和模板化创建；
- input/output schema；
- 知识依赖、工具需求、effects 和风险等级；
- golden cases、回归测试和确定性门禁；
- Git/CI 版本、review、digest 和变更记录；
- 非生产 profile 装载、运行、反馈和回滚；
- 至少一种已验证的分发路径；TeamAI 可选，失败时可由管理员发布 fallback；
- SkillHub/TeamAI 不可用时的管理员发布 fallback。

运行能力

- 一次运行同时记录 knowledge version、skill version/digest、profile、run、工具调用和人工确认；
- 结果可以反馈到知识复核或 Skill 回归，不自动修改正式资产。

5. 明确不做

- 不让模型直接发布知识或 Skill；
- 不让 Skill 自行获得工具权限或扩大数据范围；
- 不把 WeKnora 当作 Skill Registry；
- 不把 Bot Memory、群聊结论或运行日志当正式资产；
- 不在首期建设多租户微服务、Agent 市场、开放 Plugin Marketplace 和高风险生产写入；但为受控 Plugin manifest、权限和运行归因预留接口；
- 不把 TeamAI 作为知识 + Skill MVP 的硬依赖，也不允许 TeamAI 的 Hook 绕过 MR、CI、审核、版本 pin 或权限授予；
- 不以 SkillHub 或 TeamAI 的自动化功能绕过审批；
- 跨团队数字员工和公共 Agent/Skill 联邦属于后续复用场景，不阻塞单团队 MVP；
- 不因为一个 Skill 在一次任务中成功就自动晋升 stable。

6. 价值与退出标准

观察：有效引用率、Skill 任务成功率、人工纠正率、重复提问/整理下降、从草稿到可用版本的耗时、过期率、回滚时间和复核关闭时间。

如果知识或 Skill 不能减少重复劳动、返工或交接成本，应停止扩展，先重新评估场景。

02-端到端知识工作流

端到端知识工作流

> 本文描述业务如何把知识和任务能力变成可运行资产。数据字段见[数据、状态与可追溯性](./06-数据、状态与可追溯性.md)，发布门禁见[发布、安全与故障处置](./07-发布、安全与故障处置.md)。

1. 两条生产线

知识生产线

```
资料/会议/复盘
  → 收件箱
  → Agent 生成候选知识卡片
  → 贡献者确认事实和来源
  → steward 确认范围、例外和敏感等级
  → Git 变更包/MR
  → CI + 审核
  → WeKnora 索引确认
  → 可引用知识
```

Skill 生产线

```
任务需求/重复劳动
  → Skill 需求卡
  → Agent 生成 Skill 草稿
  → owner 确认输入、输出、边界和预期结果
  → 声明知识依赖、工具需求、effects、风险和 profile
  → 契约/安全/golden/regression 检查
  → Git 变更包/MR
  → 审核
  → 非生产 profile 装载
```

```
  → 可回放运行
  → beta/stable 或退回修改
```

2. Plugin 能力线（长期扩展）

Plugin 不是业务任务 Skill，而是向平台提供工具或外部系统适配能力。首期只预留契约和运行归因，不建设开放 Plugin 市场；待双资产稳定后，先以一个低风险、受控的适配器验证管理闭环：

```
外部系统/工具需求
  → Plugin manifest/适配器草稿
  → owner 确认 tools、权限、数据范围和兼容性
  → 安全/依赖/SBOM/沙箱/超时幂等检查
  → Git 变更包/MR
  → 审核和打包 digest
  → 安装/启用/health 读回
  → profile 注册工具
  → Skill 调用并记录 tool call
  → 禁用、撤回或回滚
```

Plugin 提供工具能力，Skill 组合工具完成业务任务；一个 Plugin 可以被多个 Skill 复用，一个 Skill 也可以依赖多个 Plugin。Plugin package 可以捆绑 Skill，但安装单位和业务能力单位仍然分离。

3. 分发与同步线（Skill/Agent）

分发线只处理已经通过治理和发布门禁的版本，不决定知识事实、Skill 质量或 Plugin 权限：

```
批准变更
  → package/digest
  → SkillHub、TeamAI distribution adapter 或管理员流程
  → 目标 dsh/profile 安装或注入
  → 实际版本/文件清单/profile 读回
  → beta/stable 生效
  → run 关联 installed revision
```

TeamAI 通过团队 Git 仓库提供 `init`、`pull`、变更分支上的 `push`、版本切换和本地 dsh 注入能力。它适合解决多人本地配置同步、新人接入、版本一致性、回滚和跨团队 Agent 包复用，但不是首期硬依赖。

安全约束：

- `teamai push` 只能推送个人分支或变更请求，不得直达 protected `main`；
- Hook 可以降低同步成本，不得绕过 CI、人工审核、版本 pin、权限授予或稳定发布；
- 自动同步只同步已批准版本，不能让未审核内容立即全员生效；
- pull/install 半成功、版本漂移、删除清理失败和状态未知必须进入对账，不得显示为成功；
- 外网或跨安全域环境只允许脱敏/公开样本，不能自动同步生产凭据、敏感正文或高风险工具。

TeamAI 未验证或不可用时，使用 SkillHub 或管理员发布；分发实现可替换，但 package、digest、profile、安装读回和回滚语义不能丢失。

4. Agent Manifest 的后续复用

Agent Manifest 是多个 Skill、知识 Profile、模型/运行策略和工具依赖的组合/分发包，适合将一个团队开发的 Agent 复用到其他团队：

```
Agent Manifest
  → 引用固定 Skill/version/digest
  → 引用知识 profile/version
  → 声明模型、工具和运行策略
  → 依赖审核通过
  → 分发到目标 dsh/DS Bot
  → 运行时仍按 Skill、知识和 Plugin 各自归因
```

它不是新的 canonical source，也不能替依赖资产审批；一个 Agent 包不能绕过 Skill 回归、知识 ACL、Plugin 权限或人工 gate。跨团队数字员工属于 P3 以后或更远期场景，不阻塞单团队 MVP。

5. 两条线如何汇合

```
用户任务
  → 选择 profile 和固定 Skill digest
  → Skill 调用 WeKnora 检索已授权知识
  → DSH 执行工具和人工确认
  → 返回结果、知识引用、Skill 版本和运行状态
  → 用户/业务结果反馈
  → 知识复核任务 或 Skill 回归任务
```

Skill 不复制知识正文；运行时必须获得结构化的 `knowledge_id/version/source`。知识版本变化、Skill 契约变化和 profile 变化都应能从一次 run 中识别。

6. 每一步的责任和证据

| 步骤 | 责任人 | 输出 | 最低证据 |

|---|---|---|---|

| 收件/需求 | 贡献者 | 原始资料或 Skill 需求 | 来源/任务、捕获人、时间 |

| 生成草稿 | 模型/平台 | 知识或 Skill 草稿 | 输入引用、生成 run |

| 业务确认 | 贡献者/steward/owner | 已确认草稿 | 差异、确认人、待解决项 |

| 确定性验证 | 脚本/CI | 门禁结果 | schema、secret、测试和依赖结果 |

| 审核 | steward/审核人 | approved 变更 | approval、版本、理由 |

| 发布/装载/分发 | worker/管理员/TeamAI adapter | published、loaded 或异常 | index job、release、digest、distribution target、installed revision、profile |

| 运行 | 使用者/DSH | 结果和运行记录 | run、knowledge、skill、tool、人工 gate |

| 反馈 | 使用者 | 复核、回归或分发故障任务 | 上下文、版本、差异和业务结果 |

7. 反馈分流

- 知识事实、范围、例外或引用错误 → 知识复核；
- Skill 输入输出、步骤、工具调用或结果质量错误 → Skill 回归/修订；
- Plugin API、凭据、安装、兼容性、健康或运行时错误 → Plugin/平台故障任务；
- 分发同步失败、版本漂移、安装读回失败、Hook 冲突或删除清理失败 → 分发故障任务；
- 权限、敏感性或 profile 错误 → 权限治理任务；
- 运行基础设施失败 → 平台故障任务；
- 业务需求发生变化 → 新的 Skill/知识需求。

反馈不能直接覆盖正式资产。一次成功运行也不能自动形成知识规则或 stable Skill。

8. 非程序员体验

业务人员只需要理解：**提交、确认、审核、选择、运行、反馈**。分支、commit、MR、pipeline、index job、package digest 和 profile 细节可以查看，但由平台 owner 和 coding agent 维护，不要求业务人员手工操作。

9. 异常分支

来源不足停在 candidate；契约或测试失败停在 validating；审核退回停在 authoring/reviewing；索引或装载失败进入补偿；provider 超时进入 unknown/reconciling；高风险动作没有 approval 则拒绝；所有异常保留人工流程。

03-知识资产与生命周期

知识与 Skill 资产模型

> 知识和 Skill 是两类一等资产：知识描述 Agent 应该知道什么，Skill 描述 Agent 如何完成一类任务。两者共享治理底座，但不能混成一种资产。

1. 双资产关系

```
Knowledge asset                    Skill asset
事实/规则/案例/流程/决策             可重复任务的执行契约和实现
        ↑ source/evidence                  ↓ depends_on
        └──────────────── 一次 Agent run ────────────────┘
                          profile + tools + outcome
```

Skill 可以依赖一个或多个知识域/固定知识版本；它不能复制正式知识正文，也不能自行改变知识的权限和状态。

2. 资产分层

| 资产 | 说明 | 首期 |

|---|---|---:|

| 原始证据 | 说明发生了什么 | 必须 |

| 知识卡片 | 事实、规则、案例、流程和决策 | 必须 |

| Skill 需求 | 说明要重复完成什么任务 | 必须 |

| Skill 包 | 契约、实现、测试、依赖和风险声明 | 必须（低风险） |

| 运行记录 | 说明一次任务实际发生了什么 | 必须 |

| 反馈/复核任务 | 说明知识或 Skill 哪里需要改 | 必须 |

| Plugin package / MCP | 受控工具和外部系统适配能力 | 后续（双资产稳定后） |

| Bot Memory | 运行时上下文和协作记忆 | 可选，不是正式资产 |

3. 知识资产

元数据

```
id: knowledge.<domain>.<name>
version: 1.0.0
kind: fact | rule | case | procedure | decision
status: captured | candidate | reviewing | approved | publishing | published | stale | deprecated | rejected
owner: team-owner
steward: user-id
source_refs: []
applies_to: []
not_applies_to: []
last_reviewed_at: timestamp
next_review_at: timestamp
evidence_level: E0 | E1 | E2 | E3
sensitivity: public | internal | confidential | restricted
```

正文

1. 一句话结论；

2. 已确认事实；

3. 依据和来源；
4. 适用条件；
5. 不适用范围和例外；
6. 推断或建议（单独标记）；
7. 反例和未知项；
8. 下一次复核条件。

生命周期

```
captured → candidate → reviewing → approved → publishing → published
```

异常/终态：`index_failed`、`index_unknown`、`stale`、`deprecated`、`rejected`、`manual_required`。

只有真实索引确认才能进入 `published`。证据等级不是模型置信度：E0 是未核验输入，E1 是单一来源和基本确认，E2 是责任人确认且有支持来源/记录，E3 是多场景验证并有边界。

4. Skill 资产

元数据

```
id: skill.<domain>.<name>
version: 0.1.0
status: requested | scaffolded | authoring | validating | reviewing | approved | beta | stable | blocked | withdrawn | deprecated | retired
owner: team-owner
backup_owner: user-id
purpose: structured task description
knowledge_dependencies:
  - id: knowledge.<domain>.<name>
    version: 3.0.1
input_schema: contract/input.schema.json
output_schema: contract/output.schema.json
effects: contract/effects.yaml
risk_level: L0 | L1 | L2 | L3 | L4 | L5
compatible_profiles: []
package_digest: sha256:...
```

最小 Skill 包

```
skills/<domain>/<name>/
├── SKILL.md
├── skill.yaml
├── contract/input.schema.json
├── contract/output.schema.json
├── contract/effects.yaml
├── tests/golden/
├── tests/regression/
├── dependencies.lock
└── CHANGELOG.md
```

Skill 生命周期

```
requested → scaffolded → authoring → validating → reviewing → approved → beta → stable
                                                    ↘ blocked/rejected
stable → withdrawn/deprecated → retired
```

`approved` 表示资产和审核通过；`beta/stable` 表示可被哪些 profile 装载；不能把 Git 合并、SkillHub 上传或一次运行成功混为同一状态。

5. Plugin 资产（长期扩展）

Plugin 是平台或 Agent 可调用的受控外部能力，提供工具、服务适配器或运行时扩展；它不描述一类业务任务，也不替代 Skill。首期不建设开放 Plugin Marketplace，但应预留独立 manifest、权限和运行归因边界。

最小 metadata

```
id: plugin.<domain>.<name>
version: 0.1.0
status: requested | authoring | validating | reviewing | approved | installed | enabled | disabled | withdrawn | retired
owner: team-owner
backup_owner: user-id
host_compatibility: ">= 2.0.0"
tools:
  - name: query_records
    input_schema: contract/query.schema.json
    output_schema: contract/result.schema.json
permissions:
  network: []
  data: []
  filesystem: []
required_secrets: []
dependencies: []
package_digest: sha256:...
health_check: configured
```

Plugin 必须声明工具、权限、网络/数据范围、凭据需求、宿主兼容性、依赖、digest、health 和 owner。实际权限仍由 profile、tool policy、workspace、环境和运行时授权共同决定。

Plugin 生命周期

```
requested → authoring → validating → reviewing → approved → installed → enabled
                                                          ├→ disabled
```

```
                                                  └→ rejected/blocked
enabled → withdrawn/deprecated → retired
```

`approved` 表示 package、manifest、安全和兼容性审核通过；`installed` 表示目标环境已安装；`enabled` 表示健康检查和权限授予均已确认。它们不能与 Skill 的 `stable` 或一次工具调用成功混为一谈。

Plugin package 可以捆绑一个或多个 Skill，但 Plugin 是安装/运行单位，Skill 是业务能力单位，必须分别版本、审核、测试和回滚。

6. Agent Manifest 与分发包

Agent Manifest/分发包（后续复用）

Agent Manifest 是对可运行 Agent 的组合描述，可以引用固定的 Skill/version/digest、知识 profile/version、模型配置、工具需求、运行策略和人工确认点。它适合支持 TeamAI 的跨团队 Agent 分发，但不拥有被引用资产的 canonical source，也不能绕过各自的 owner、ACL、回归和审批。

建议结构：

```
id: agent.<domain>.<name>
version: 0.1.0
skills:
  - id: skill.<domain>.<name>
    version: 1.2.0
    digest: sha256:...
knowledge_profiles: []
model_profile: default
plugin_tools: []
human_confirmation: required
compatible_targets: []
```

分发 metadata

TeamAI 或其他分发适配器可以记录 `distribution_target`、`workspace_id`、`source_revision`、`package_digest`、`installed_revision`、`profile_version`、`sync_status` 和 `last_error_code`。这些字段只说明版本如何到达目标环境，不改变知识、Skill 或 Plugin 本身的生命周期状态。

7. Skill 必须声明和验证

- 输入和输出 schema；
- 依赖的知识 ID、版本策略和引用要求；
- 工具需求、读写 effects、网络和数据范围；
- 风险等级和人工确认点；
- golden cases、回归集和失败态；
- 依赖、许可证、SBOM 和 package digest；
- 兼容 profile、运行环境和资源限制；
- owner、审核人、变更记录、回滚版本和退役条件。

自然语言说明不能替代机器可读契约；Skill 不能自行获得权限、直接写正式知识或依赖漂移的 `latest`。

8. 版本关系

| 标识 | 含义 |

|---|---|

| Git commit | 知识或 Skill 源码不可变变更 |

| knowledge version | 面向业务的知识修订号 |

| Skill semver | Skill 分发版本 |

| Plugin semver | Plugin package 分发版本 |

| Plugin digest | Plugin 内容完整性 |

| index version | WeKnora 索引版本 |

| profile version | DSH 实际装载的资产集合 |

| run | 一次实际运行和结果 |

必须能够追踪：

```
run → profile/version → skill/version/digest + plugin/version/digest → knowledge/version/source → Git commit
```

9. 资产边界

- WeKnora 不是 Skill Registry；
- SkillHub 不是知识审批系统；
- Plugin Registry/Runtime 不是 Skill 业务质量管理系统；
- DSH 不是正式源和发布审批系统；
- 运行记录同时关联 `knowledge/version`、`skill/version/digest`、`plugin/version/digest`、`profile` 和 `tool calls`；
- 反馈是候选/任务，不是正文、代码或 Plugin package；
- 一次运行成功不等于知识成立、Skill stable 或 Plugin enabled。

04-角色、治理与运营机制

角色、治理与运营机制

1. 三类责任

```
模型：提取、摘要、分类、起草、发现冲突、生成测试候选
脚本/CI：校验 schema、权限、依赖、secret、回归和差异
人：确认事实、范围、任务边界、风险、批准发布和高风险动作
```

2. RACI

活动	平台 owner	Distribution/platform owner	贡献者	知识 steward	Skill owner	Plugin/integration owner	审核人
模板和门禁	A/R	C	C	C	C	C	I
提交资料/任务需求	I	I	R	C	C	C	I
生成知识/Skill 草稿	A	C	C	C	C	C	I
确认知识事实和范围	I	I	R	A/R	C	I	C
确认 Skill 契约和预期结果	I	C	C	C	A/R	C	C
权限/effects/profile 审核	A/R	C	I	C	R	C	A
CI、安全和回归检查	A/R	C	I	I	C	C	I
发布知识/Skill/Plugin	C	R	I	R	R	R	A
运行反馈分流	R	R	C	A（知识）	A（Skill）	A（Plugin/平台）	C
退役/回滚	R	R	I	A（知识）	A（Skill）	A（Plugin/分发）	A

早期一人可以兼任多个角色，但知识责任、Skill 责任和分发责任必须分别明确，不能因为同一个人兼任就把审核、发布和安装读回混为一类。

3. 必须人工确认

知识

事实、来源、适用范围、例外、敏感等级、跨域可见性、复核日期和是否足以形成通用规则。

Skill

任务是否值得固化、输入输出是否完整、失败态和例外、知识依赖是否正确、工具/effects 是否必要、风险等级、测试结果、profile 兼容性、beta/stable、撤回和回滚。

Plugin

Plugin owner 必须确认工具 manifest、外部系统边界、权限和凭据需求、宿主兼容性、依赖/SBOM、沙箱或进程隔离、超时/重试/幂等、health、禁用和回滚。Plugin 只能声明能力需求，不能自行授予权限或把 provider 响应变成系统指令。

分发

TeamAI 或其他 distribution adapter 的目标仓库、分支保护、版本 pin、profile 兼容、secret 扫描、Hook 限制、删除清理、安装读回、回滚和审计。Agent Manifest 必须逐项引用已批准的 Skill、知识 profile 和工具权限，不能用组合包绕过任何依赖资产门禁。

共同

任何生产写入、不可逆动作、对外发送、权限扩大和数据范围扩大。分发同步也必须经过批准版本、目标范围确认和实际安装读回。

4. 风险等级与 gate

级别	示例	默认控制
L0	只读检索、证据卡片	可自动执行，记录审计
L1	摘要、候选、草稿	可自动执行，标记未验证
L2	隔离环境计算和回放	限资源、网络和数据范围
L3	创建任务、修改临时状态	范围校验和可恢复记录
L4	敏感读取、业务写入	人工确认、最小权限、读回比对
L5	生产、不可逆或现场动作	强制 gate、双人审批、急停和回滚

Skill 只能声明能力需求，实际权限由 DSH profile、tool policy、用户、workspace、环境和运行时授权共同决定。

5. Skill 治理门禁

一个 Skill 进入 beta 前必须有：契约、知识依赖、effects/权限声明、golden cases、回归结果、owner、固定版本和非生产 profile。

进入 stable 前还必须有：真实任务证据、失败和人工纠正记录、依赖和 SBOM、digest、运行归因、回滚 pin、下一次复核日期和明确批准。

禁止：模型自动标 stable、相似度自动合并 Skill、Skill 自行增加工具、用一次成功运行替代回归、用 `latest` 代替固定版本。

6. Plugin 治理门禁（P4 起）

一个 Plugin 进入 `enabled` 前必须有：manifest、工具 input/output schema、最小权限和数据范围、Secret Manager 引用、依赖/许可证/SBOM、宿主兼容性、health/readback、安装审计、失败清理和回滚 pin。涉及敏感数据、网络写入或不可逆动作时，必须增加沙箱、人工确认、限流、幂等和读回比对。

Skill 质量治理与 Plugin 运行时治理分开：Skill 关注任务结果、知识依赖和回归；Plugin 关注工具安全、外部系统兼容性和运行可靠性；分发治理关注版本到达、目标一致性和安装证据。三者共享审批、审计、profile 和 run trace。

7. 运营节奏

知识 steward 检查事实/范围；Skill owner 检查契约/测试/effects；Plugin owner 检查 manifest/权限/兼容性/health；平台 owner 检查 CI、权限和发布证据。

每周复核队列

分别处理知识错误/过期/引用失效、Skill 失败/纠正率/契约冲突、Plugin API/health/权限/兼容性问题、profile 权限异常、索引/装载失败和人工补偿任务。

每月质量回顾

同时看：有效知识引用率、Skill 任务成功率、Plugin 可用率/故障率、分发同步成功率、版本漂移率、安装失败率、新人接入耗时、跨团队复用率、人工纠正率、运行成本/延迟、版本回滚、过期率、复核关闭时间和重复劳动下降情况。

8. 反馈分流

| 反馈 | 进入的治理任务 |

|---|---|

| 事实、范围、引用错误 | 知识复核/MR |

| 输入输出不匹配 | Skill 契约修订 |

| 步骤或结果质量错误 | Skill 回归/MR |

| Plugin API、凭据、健康或兼容性错误 | Plugin 禁用/回滚和平台故障 |

| 分发同步、版本漂移、安装读回或删除清理错误 | 分发故障、回滚和人工对账 |

| 业务规则变化 | 知识和依赖 Skill 联合复核 |

| 运行基础设施失败 | 平台故障和补偿 |

反馈不直接覆盖正式知识或 Skill。试点先选择 5–8 名高频使用者和一个知识域/任务，证明双资产闭环有价值后再扩展。

05-系统架构与权威边界

系统架构与权威边界

1. 当前推荐拓扑

```
贡献者 / steward / Skill owner
            ↓
轻量 Web/API 向导或已验证的 DSH 入口
            ↓
双资产生产与治理模块化单体 + 持久化 worker
  ├─ Knowledge catalog / review / change
  ├─ Skill catalog / contract / test / release
  ├─ Plugin catalog / manifest / permission（P4 起）
  ├─ operation / job / approval / audit / feedback
  ├─ Git provider / CI
  ├─ WeKnora adapter
  └─ SkillHub / TeamAI / Plugin registry adapter（验证后；否则管理员流程）
            ↓
分发适配层（可选）
  └─ TeamAI distribution adapter / local sync（init、pull、版本切换、dsh 注入）
            ↓
DSH profile / loader / tools / human gate / run
  ├─ 可选 OpenCSG AI Gateway / Agent runtime（目标环境验证后）
  └─ Plugin runtime / gateway / tool registry（P4 起）
```

第一版只有一个新增控制面，但它同时是一等管理知识和 Skill 的资产控制面，并为未来 Plugin catalog/registry、TeamAI 分发适配器和 Agent Manifest 预留独立边界，不是只管理知识的服务。异步动作先用数据库任务表、租约、重试、读回和人工补偿。

2. 权威边界

| 对象 | 权威来源 | 负责什么 | 不负责什么 |

|---|---|---|---|

| 原始资料/任务需求 | 收件箱/受控附件 | 保存输入和捕获信息 | 直接成为正式资产 |

| 正式知识 | Git + MR/CI/人工审核 | 正文、来源、差异、版本、回滚 | 下游直接修改 |

| 知识检索 | WeKnora | 索引、ACL、查询、引用 | 决定批准或管理 Skill |

| 正式 Skill | Git + MR/CI/人工审核 | 源码、契约、测试、依赖、版本 | 运行时自行改写 |

| Plugin package | Git + CI + package digest（P4 起） | manifest、工具 schema、适配器、依赖和权限声明 | 直接获得运行权限 |

| Plugin 注册/安装 | Plugin registry/管理员记录（P4 起） | package、digest、安装、启停、撤回和兼容性 | 决定业务任务质量 |

| Skill 注册/分发 | SkillHub、TeamAI distribution adapter 或管理员记录 | package、digest、beta/stable、撤回、目标安装和版本切换 | 决定业务事实或直接授予权限 |

| TeamAI 分发/同步 | Git 批准版本 + TeamAI adapter 运行记录（验证后） | init、pull、变更分支 push、本地映射/注入、版本切换和安装读回 | 审批知识/Skill、管理知识索引、决定 Plugin health 或授予运行权限 |

| Agent Manifest | Git + CI + 人工审核（后续） | 多个 Skill、知识 profile、模型/工具策略的组合和分发描述 | 替代依赖资产的 owner、审核、ACL 或回归 |

| 执行和工具权限 | DSH profile/policy + Plugin runtime/tool registry（后续） | 装载、工具、人工确认和运行 | 改变 canonical source |

| 运行反馈 | run/trace/反馈表 | 归因、质量和候选任务 | 直接发布资产 |

| 资产/任务/审计状态 | 工作台数据库 | catalog、job、approval、补偿和关联 | 代替 Git/WeKnora/DSH 的专业能力 |

3. 组件职责

Plugin 管理（P4 起）

Plugin 提供工具能力或外部系统适配，不提供业务任务方法。Plugin catalog/registry 管理 manifest、版本、digest、兼容性、安装、启停、健康、撤回和权限授予；Plugin runtime/gateway 负责隔离执行、凭据注入、超时/重试/幂等、tool registry 和真实状态读回。Skill 通过 profile 使用 Plugin 工具，但 Plugin 管理不替代 Skill 管理。

进入 P4 的触发条件包括：出现第二个外部系统或重复适配、多个 Skill 复用同一工具、需要集中权限/凭据治理、需要沙箱/进程隔离，或模块化单体无法接受地管理安装和运行。

工作台控制面

提供业务人员的统一入口和平台 owner 的控制面：资产目录、知识/Skill 草稿、变更包、审核、任务状态、profile 选择、发布状态、反馈、审计和人工补偿。

它不存放未经治理的正式正文，也不绕过下游真实状态。

Git/CI

保存知识、Skill、Plugin manifest/适配器、schema、测试、metadata、依赖锁定、CODEOWNERS 和变更历史。执行格式、secret、契约、权限冲突、链接、依赖和回归门禁。

WeKnora

只接收批准后的知识，提供权限过滤、检索、来源和版本引用。它不能管理 Skill 的契约、测试、发布或运行权限。

TeamAI 分发适配层（验证后）

TeamAI 只负责已批准团队 AI 资产的分发和本地同步：仓库镜像、`init`、变更分支上的 `push`、`pull`、版本切换、目标 workspace 映射/注入和安装读回。它可以承载 Skills、Rules、Agent Manifest 和受控 Plugin manifest 的分发，但不负责知识事实审批、Skill 业务质量、WeKnora 检索、Plugin runtime、权限授予或统一 run 的最终归因。

自动同步不等于自动批准或自动生效。TeamAI 只能消费已通过 MR/CI/人工审核的版本；实际运行前必须确认 target、profile、installed revision 和权限状态。不可用时必须回到 SkillHub 或管理员 fallback。

SkillHub

提供 Skill package 的注册、分发、版本和 digest（目标部署验证后）。未验证时由管理员流程保证同样的版本、审批、装载和回滚语义。

OpenCSG 运行层（验证后）

参考方案将 OpenCSG 定位为模型推理、Agent 编排、AI Gateway 和多 Agent 协作运行层；本项目只把它作为待验证 provider，不因外部方案描述而视为已集成。其资产托管、AgenticHub、CSGClaw 或本地模型能力必须分别验证，不能替代工作台、Git、WeKnora、Skill 分发或 Plugin 治理。

DSH

提供 profile、Skill loader、Session、工具调用、人工确认和运行结果。它不拥有知识/Skill 的正式源，也不自动批准发布。

DeepSeek Bot

可选的 DSH 协作层，提供 Bot、Group、Memory 和交接；不能替代资产治理、SkillHub、Git、WeKnora 或企业审批。

4. 当前不引入的层

完整 Integration Gateway、Plugin Registry/Runtime、Console Plugin、MCP 高风险工具、多 provider、服务端 Bot Host、多租户和 TeamAI 自动分发不是 P1 的硬依赖。TeamAI 先只做能力侦察或可选 adapter，只有双资产稳定且出现真实分发触发证据后才进入 P3；Plugin 只有出现外部系统复用、集中权限或运行时隔离需求后才进入 P4。

这不影响知识和 Skill 管理是当前产品核心；延后的是 TeamAI 自动分发、Plugin 等更重的实现层，不是 Skill 资产能力。

5. 不可混淆的边界

- WeKnora 是知识检索，不是 Skill 管理；
- SkillHub/TeamAI 是分发实现，不是知识事实审核；
- TeamAI 的 pull 成功不等于 Skill stable、Plugin enabled 或运行成功；
- DSH 是执行面，不是资产 canonical source；
- MCP 是调用协议，不是异步控制面；
- Webhook 是事实通知，不是授权；
- HTTP 200 不是业务成功；
- 一个 Agent 的成功回答不是通用规则；
- 一个统一页面不等于系统统一。

06-数据、状态与可追溯性

数据、状态与可追溯性

1. 资产状态

知识

```
captured → candidate → reviewing → approved → publishing → published
```

异常/终态：`index_failed`、`index_unknown`、`stale`、`deprecated`、`rejected`、`manual_required`。

Skill

```
requested → scaffolded → authoring → validating → reviewing → approved → beta → stable
                                                    ├→ blocked
                                                    └→ rejected
stable → withdrawn/deprecated → retired
```

Plugin

```
requested → authoring → validating → reviewing → approved → installed → enabled
                                                      ├→ disabled
                                                      └→ blocked/withdrawn
```

Plugin `enabled` 必须同时有安装读回、权限授予、兼容性检查和健康证据；`installed`、`enabled`、`healthy` 和一次工具调用成功不能混为一谈。

发布/装载/启用不能混为一谈

- `approved`：源文件、契约和审核通过；
- `published`：知识索引真实确认或 Skill package 分发真实确认；
- `loaded`：DSH profile 实际装载了固定 Skill digest；
- `installed`：Plugin package 在目标环境安装读回；
- `enabled`：Plugin 权限授予、兼容性和 health 均已确认；
- `succeeded`：一次运行有真实结果或人工验证；
- `stable`：Skill 经过明确治理批准，可供指定 profile 使用。

2. 运行和反馈状态

异步运行

```
created → queued → running → waiting_human → succeeded
                                    ├→ failed
                                    ├→ timed_out
                                    ├→ cancelled
                                    └→ unknown → reconciling → succeeded/failed/manual_required
```

反馈复核

```
created → triaged → assigned → in_progress → resolved
                                  ├→ rejected
                                  ├→ deferred
                                  └→ escalated
```

反馈任务必须标明目标：`knowledge_review`、`skill_regression`、`distribution_incident`、`permission_review` 或 `platform_incident`。

3. 最小数据模型

```
workspace
actor
asset
asset_revision
knowledge_dependency
skill_contract
skill_test_case
plugin_contract
plugin_tool
permission_grant
plugin_installation
distribution_target
distribution_installation
sync_revision
source_reference
operation
job
approval
release
installation
run
feedback
review_task
audit_event
```

关键字段：`workspace_id`、`actor_id`、`asset_id`、`asset_type`、`source_commit`、`knowledge_version`、`skill_version`、`plugin_version`、`package_digest`、`plugin_digest`、`profile_version`、`distribution_adapter`、`distribution_target`、`source_revision`、`installed_revision`、`sync_status`、`permission_grant_id`、`provider_health`、`idempotency_key`、`correlation_id`、`state_version`、`last_error_code`。

4. 最小追踪链

```
actor
  → operation
  → job
  → asset revision
  → Git commit/MR/CI
  → release/index job/distribution installation/plugin health/permission grant
```

```
  → profile + installed revision
  → run
  → knowledge refs + skill digest + plugin digest + tool calls
  → feedback/review task
```

若引入 DSH/DeepSeek Bot，再追加 `dsh_session_id`、`bot_id`、`room_id`、`exchange_id`。资产版本、知识引用和 Skill digest 必须由系统注入，不能从模型文本猜测。

5. 幂等和恢复

- 所有创建、提交、发布、装载和反馈写操作使用 idempotency key；
- 状态更新带 expected state/state version，旧回调不能覆盖新状态；
- 重试前先读回 provider 的 branch/MR/index/package/profile/plugin installation/health 和 distribution installation/sync 状态；
- TeamAI pull 或安装半成功、删除清理不完整、版本漂移和断网状态进入 `unknown`/`reconciling`，不能直接标成成功；
- worker 崩溃由租约扫描恢复；无法确认进入对账；
- 事件落库后再确认接收；
- 删除优先软退役，保留旧版本、digest、审计和回滚 pin。

6. 状态证据

| 状态 | 必须证据 |

|---|---|

| knowledge published | index confirmation、document/version/source |

| skill approved | Git commit、CI、contract/test、approval |

| skill beta/stable | release、digest、profile compatibility、批准和回滚 pin |

| distribution installed | target、source/package digest、installed revision、文件清单/profile 读回和同步状态 |

| plugin enabled | installation、permission grant、host compatibility、health/readback、digest |

| succeeded | 实际结果或人工验证 |

| unknown | 对账记录和人工处理状态 |

业务原文、密钥、Cookie、密码、个人敏感信息和工具敏感参数不能进入 Git、WeKnora 正文、长期 Memory 或 trace。

07-发布、安全与故障处置

发布、安全与故障处置

1. 知识发布链

```
知识变更包
  → 服务端校验来源、路径、敏感性和幂等键
  → Git branch/MR
  → CI
  → steward/审核人批准
  → 合并受保护 main
  → WeKnora ingest
  → 真实读回 document/version/ACL
  → knowledge = published
```

2. Skill 发布链

```
Skill 变更包
  → 校验 metadata、schema、依赖、effects 和路径
  → contract/golden/regression/security CI
  → Skill owner + 审核人批准
  → 合并受保护 main
  → 打包并生成 digest
  → SkillHub 发布或管理员发布
  → 目标 profile 安装/装载读回
  → beta/stable 或 blocked
```

SkillHub 不可用时，不取消 Skill 管理：使用 Git package、管理员发布、固定 digest、DSH 非生产 profile 和人工回滚，直到自动分发能力验证完成。

3. Plugin 发布链（P4 起）

```
Plugin manifest/适配器
  → 校验工具 schema、权限、网络/数据范围、凭据引用和宿主兼容性
  → security/dependency/license/SBOM/sandbox CI
  → Plugin owner + 平台/安全审核
  → 合并受保护 main
  → 打包并生成 digest
  → 安装并授予最小权限
  → health/版本/工具注册读回
  → enabled 或 blocked
```

首期不建设开放 Plugin Registry/Marketplace；可以保留受控内置适配器或 fake provider contract，但不能把“存在工具接口”报告为 Plugin 已安装或可用。

4. 分发发布链（TeamAI/SkillHub，验证后）

```
已批准 Skill/Agent Manifest/受控配置
  → package/digest 和目标 profile
  → TeamAI distribution adapter、SkillHub 或管理员流程
  → target workspace pull/install
  → dsh 文件清单、installed revision、profile 和权限读回
  → beta/stable 生效
```

TeamAI 的 `push` 只能进入个人分支或变更请求；任何 Hook、自动 pull 或本地映射都不能绕过 protected main、CI、人工审核、版本 pin、Secret 扫描或权限授予。自动同步只消费已批准版本，不能把未审核草稿直接注入所有成员的 dsh。

分发门禁

目标仓库和分支保护、路径/删除安全、secret 和敏感信息扫描、依赖锁定、profile 兼容、版本 pin、Hook 权限限制、幂等、安装/删除清理、文件清单读回、回滚和审计。外网或跨安全域只允许脱敏/公开样本，不得同步正式敏感知识、生产凭据或高风险工具。

TeamAI 不可用或目标能力未验证时，使用 SkillHub 或管理员发布，保持 package、digest、profile、安装读回和回滚语义。

5. CI 门禁

共同门禁

格式、schema、ID、路径、owner、sensitivity、来源、secret、个人敏感信息、重复 canonical key、链接、CODEOWNERS、受保护分支和变更范围。

Skill 门禁

input/output schema、知识依赖、effects 和 profile 权限兼容、依赖锁定、许可证/SBOM、golden/regression、digest 生成和危险权限变更。

Plugin 门禁

manifest、tool input/output schema、最小权限、Secret Manager 引用、网络/数据范围、依赖锁定、许可证/SBOM、宿主兼容性、沙箱/进程隔离、超时/重试/幂等、health、digest、安装/卸载清理和危险权限变更。

CI 判断机器可验证事实，不能代替业务 steward、Skill owner 或 Plugin owner 判断事实、任务价值和外部系统责任。

6. 审核规则

- 知识结构/格式变更：至少 1 名 steward；
- 知识事实、范围、敏感等级变更：steward + 领域审核人；
- Plugin manifest、权限/凭据、宿主兼容性、health 或安装变更：Plugin owner + 平台/安全审核；
- 跨域、机密、权限和生产写入：双人审核或额外 owner 批准；
- beta/stable、撤回、退役和回滚：明确责任人和审计理由；
- 合并前重新检查 head SHA、CI 和 approval。

7. 权限和数据保护

Skill 只能声明能力需求，实际权限由用户、workspace、profile、tool policy、环境和运行时授权共同决定。普通 Agent 默认看不到高风险工具；工具调用必须重新校验 schema、ACL、risk 和 approval。

Git 只保存脱敏内容、Skill 源码、测试和引用；WeKnora 按文档、空间、用户和业务域过滤；Secret 通过受控 Secret Manager 提供，不进入 Prompt、Skill、Git、Memory 或 trace。

8. 审计

发布、安装、装载、运行、权限变更、索引、审批、回滚和撤回至少记录：actor、action、resource/type、version、source commit、package digest、profile、request、reason、result、时间和 correlation。

审计必须能关联 Git MR/CI、WeKnora index job、SkillHub release、installation、approval、run 和最终真实状态。

9. 故障处置

- CI 失败：不发布；
- WeKnora 索引失败：保留旧索引，进入补偿；
- SkillHub/TeamAI/仓库不可用：继续使用已固定 package 或管理员发布，禁止漂移；
- TeamAI pull/install 半成功、版本漂移、注入失败或 Hook 冲突：标记 unknown/reconciling，停止新启用，读回目标文件清单并人工对账；
- 删除或回滚清理失败：保留旧 profile pin，隔离残留文件并升级人工处理；
- Plugin runtime/外部 provider 不可用：工具标记 unhealthy/unknown，禁止新运行使用，读回或人工对账；
- Plugin 权限、凭据或兼容性变更失败：禁用并保留旧 package/profile pin；
- provider 超时：unknown，读回或人工对账；
- Webhook 丢失：轮询或人工确认；
- 权限服务不可用：敏感工具拒绝；
- 回滚失败：冻结后续发布并升级人工处理。

10. 回滚

知识

定位错误版本 → 冻结/退役 → Git 回到上一有效版本 → 重新索引 → 读回检索结果 → 审计和复盘。

Skill

定位 Skill/package/profile 版本 → 停止新装载 → 回到旧 digest/profile pin → 运行 smoke/regression → 读回实际装载 → 审计和复盘。

分发

停止新同步/启用 → 定位 target、package/digest、installed revision 和 profile → 回到旧 package/digest/profile pin → pull/install 读回 → 清理新文件或残留 → smoke/regression → 审计和复盘。

Plugin

定位 Plugin/package/installation/profile 版本 → 停止新调用 → 禁用或撤回 → 回到旧 digest/profile pin → health/smoke/regression → 读回实际权限和工具注册 → 审计和复盘。

取消 HTTP 请求不代表外部动作已取消；所有取消和超时都必须补查真实状态。

08-MVP实施、验证与验收

MVP 实施、验证与验收

> 本文是唯一的实施路线和验收入口。Skill 管理从 P0 建模，从 P1 与知识闭环并行交付；Plugin 管理是双资产稳定后的长期扩展，不作为首期硬依赖。

1. 交付方式

采用：**一个知识域、一个高频低风险任务、一个 Git provider、一个 worker、一个知识 steward、一个 Skill owner、一个非生产 profile**。

每个阶段留下版本、环境、fixture、运行命令、预期/实际结果、失败动作、owner、回滚方式和 Go/No-Go 决策。

2. P0：双资产边界与能力侦察

交付

- 一个真实但脱敏、可回放的知识样本集和任务样本集；
- 知识 steward、Skill owner、备份责任人和平台 owner；
- Knowledge/Skill schema、状态机、关系和统一 run 追踪；
- TeamAI CLI/repository/hooks/local injection 的能力记录和 fake distribution contract，不要求真实 TeamAI runtime；
- Plugin manifest/tool contract 的预留边界和 fake provider contract，不要求真实 Plugin runtime；
- fake Git/WeKnora/SkillHub/DSH provider 或 adapter contract；
- Skill input/output、effects、profile 和风险模型；
- 目标版本的 DSH loader/profile、WeKnora 状态、SkillHub API 能力记录；
- 不使用生产 Token 的验证证据。

退出

双资产 schema、非法状态、幂等、权限冲突、契约失败、运行归因、故障路径和人工 fallback 均有测试；未知能力都有 owner、日期和处理方式。

3. P1：双资产 MVP 闭环

知识交付

收件箱、知识卡片、变更包、Git provider、CI/CODEOWNERS、审核、WeKnora ingest/status/search、引用和复核任务。

Skill 交付

Skill 需求卡、模板化创建、input/output schema、知识依赖、effects/权限声明、golden/regression、Git/CI 审核、digest、非生产 profile 装载、可回放运行、反馈和旧版本回滚。

- SkillHub/TeamAI 未验证时使用管理员发布，但必须保持 package、digest、profile、approval、目标和回滚状态可追踪。

P1 退出

- 非程序员不操作 Git 即可创建知识和 Skill 草稿；
- 知识检索结果带 document/version/source/ACL；
- Skill 运行能反查 version/digest/profile/knowledge refs；
- 重复请求不重复创建 MR、release、index 或 installation；
- CI 失败、契约冲突或权限超界不能发布/装载；
- DSH 装载失败、索引失败和 provider 超时有清晰状态和人工接管；
- 至少有一项真实任务使用双资产完成。

4. P2：双资产反馈与运营闭环

交付

运行和反馈关联、反馈分流、知识复核队列、Skill 回归队列、每周复核、每月质量报告、stale/纠正率/失败率/权限异常提醒、备份 owner、退役和回滚流程。

退出

反馈不直接改正式资产；连续 4 周有真实使用和复核记录；至少一个质量指标改善；知识问题能进入知识 MR，Skill 问题能进入 Skill 回归；未知状态可人工对账。

5. P3：Skill/Agent 分发与稳定发布

在 P1/P2 稳定后，比较并验证 SkillHub、TeamAI distribution adapter 和 Git/管理员流程。验证 package 注册或仓库同步、metadata、beta/stable、digest、目标 dsh/profile 安装、版本锁、灰度、revoke、audit、webhook/同步状态和回滚。

TeamAI 重点验证 `init`、变更分支上的 `push`、`pull`、本地 dsh 映射/注入、Hook 生命周期、删除清理、安装读回、版本漂移和断网恢复。只有通过 MR/CI/人工审核的版本才能同步；TeamAI 不可用时继续使用管理员发布，不改变 Skill 作为核心资产的定位。

分发实现的选择标准不是产品名称，而是固定版本、digest、profile 兼容、安装读回、灰度、撤回、回滚、审计和运行归因是否完整。Agent Manifest 的跨团队复用可以在此阶段做只读/低风险 PoC，但不阻塞单团队 MVP。

6. P4：控制台/Gateway 与受控 Plugin 管理演进

只有在两个以上知识域或 Skill 稳定使用、出现第二 provider、人工状态查询成为瓶颈、需要集中权限/审计，或模块化单体无法接受地测试发布时，才评估 Console/Gateway/adapter、Plugin catalog/runtime、签名事件和低风险 MCP。

Plugin 交付

- Plugin catalog 和最小 manifest/tool contract；
- 一个低风险外部系统适配器或受控内置 Plugin；
- 权限/凭据声明、Secret Manager 引用和 profile/tool policy；
- 安全、依赖/SBOM、兼容性、health、超时/重试/幂等门禁；
- 安装、启用、禁用、撤回、回滚和运行归因；
- Plugin 故障与 Skill 质量问题的反馈分流。

新增层不能改变 Git、WeKnora、SkillHub、DSH、Plugin package 和人工审核的权威边界。

7. P5：开放 Plugin、MCP 与高风险能力

验证第三方 Plugin、Registry/Marketplace、MCP、沙箱、多租户和生产写入。必须先有 P4 的真实价值、隔离构建、依赖扫描、审批、二次确认、观测和回滚证据。

8. 统一验收矩阵

| ID | 验证项 | 通过标准 |

|---|---|---|

| V-01 | 双资产样本和角色 | 脱敏知识/任务样本、owner/steward/备份齐全 |

| V-02 | 双资产 schema/状态 | 合法/非法/重复/并发迁移有测试 |

| V-03 | Skill 创建 | 模板、metadata、契约和知识依赖可生成并审核 |

| V-04 | Skill 门禁 | schema、effects、权限、依赖、golden/regression 有效 |

| V-05 | Git 变更 | 知识/Skill 路径安全、MR 幂等、CI/审批有效 |

| V-06 | WeKnora | 来源/版本/ACL 可读回，失败保留旧版 |

| V-07 | Skill 发布/装载 | digest、profile、安装结果和回滚可读回 |

| V-08 | 非程序员体验 | 不操作 Git 可创建、确认、审核和运行 |

| V-09 | 统一运行归因 | run 关联 knowledge version、skill digest、profile、commit |

| V-10 | 反馈分流 | 知识问题进知识复核，Skill 问题进 Skill 回归 |

| V-11 | 安全审计 | 无 secret 泄露、越权和不可追踪写入 |

| V-12 | 故障恢复 | 超时、丢回调、重复和未知状态可对账 |

| V-13 | 稳定发布 | beta/stable 有批准、真实证据、digest 和旧 pin 回滚 |

| V-14 | 运营价值 | 至少一个任务减少重复劳动或返工 |

| V-15 | Plugin 预留契约 | P0 有 manifest/tool contract、权限边界和 run 字段；不要求真实 Plugin runtime |

| V-16 | 受控 Plugin 管理（P4） | 安装、权限授予、health、tool registration、禁用和回滚均可读回 |

| V-17 | 分发 contract（P0/P3） | TeamAI/SkillHub/管理员路径中，MR、固定版本、目标安装、实际读回、权限/secret、回滚和 fallback 可验证 |

| V-18 | Agent Manifest 复用（P3+） | 依赖 Skill/知识/Profile 可追踪，不能绕过审批；不要求首期实现 |

详细平台实验见[验证材料](../验证/README.md)。

9. Coding agent 交付规范

每次只给 coding agent 一个小任务包：背景、范围、输入输出、禁止事项、失败测试、最小实现、验收命令、证据路径和回滚方式。先做 schema、状态机、fake provider、契约和回归，再做 UI 和真实 provider。

Agent 不拥有生产凭据，不直接 merge `main`，不执行任意 shell/路径，不隐藏未验证能力。完成后必须做独立 code review、安全 review 和范围检查。

10. Go/No-Go

以下任一项不通过，就保持当前阶段：双资产权限隔离、审计完整性、契约和回归、知识/Skill 版本可追踪、分发目标和安装读回、未知状态处理、旧版本保留、回滚、人工接管、secret 扫描、非程序员可用性或真实业务价值。TeamAI 失败必须可回退到管理员流程；P4 另需 Plugin 权限、安装、健康、兼容性和回滚证据。

README

验证材料

验证材料只回答一个问题：外部平台和依赖在目标环境中实际证明了什么。

它们不能定义产品范围、替代方案主线，也不能把“架构上可行”写成“已经集成”。特别要区分：

- **Skill 管理是本项目的核心产品能力；**
- **SkillHub 自动注册、分发和晋升是其中一种待验证实现能力；TeamAI 是另一种可复用的分发/本地同步实现候选。**
- **TeamAI 不是本项目的首期硬依赖；它的价值在于多人 dsh 配置同步、版本一致性、新人接入、回滚和跨团队 Agent/Skill 复用。**
- **Plugin 管理是双资产稳定后的长期扩展能力；**
- **Plugin/tool 扩展、注册、安装和权限治理是待验证实现能力，不属于首期硬依赖。**

即使 SkillHub 或 TeamAI 自动化不可用，也必须通过 Git/CI、管理员发布和 DSH 非生产 profile 保证 Skill 管理闭环可运行。

使用规则

每个验证项记录：目标版本、部署环境、测试样本、运行命令、预期结果、实际结果、失败路径、证据位置、owner、日期和下一步。

验证结论分为：

- **已确认**：有源码、官方 API 或可重复运行证据；
- **待验证**：架构上可行，但目标版本或部署环境未证明；
- **人工 fallback**：自动化接口未确认，先由管理员操作；
- **不建议依赖**：当前证据不足或风险不适合首期。

材料

- [平台与 Provider 能力验证](./01-平台与Provider能力验证.md)：Git、WeKnora、DSH、SkillHub/TeamAI 分发、Plugin/tool loader、MCP 和安全实验
- [DeepSeek Bot 能力评估](./02-DeepSeek-Bot能力评估.md)：Bot/Group/Memory 的源码事实和可选 PoC

与方案的关系

方案中的阶段和 Go/No-Go 是权威入口；验证材料只提供证据。验证结果改变方案时，必须回到[方案总览与关键决策](../方案/00-方案总览与关键决策.md)更新决策，而不是在验证文档中暗中改变架构。

01-平台与Provider能力验证

平台与 Provider 能力验证

> 本文只记录外部能力的验证问题、实验和结论，不定义产品范围。Skill 管理本身是核心产品能力；本文件只验证 SkillHub、DSH loader/profile 等自动化实现是否可用。

1. 验证分级

- **A：已存在可靠的官方 API、源码或本地文档证据，可进入 PoC。**
- **B：架构上可行，但必须在目标版本和真实部署中验证。**
- **C：前置条件未确认，只做只读、fake provider 或人工 fallback。**
- **D：当前不建议作为正式依赖。**

技术可行不等于已经集成。每个 B/C 项必须产生版本、环境、日期和结论。

2. 当前能力矩阵

| 能力 | 当前判断 | 必须验证 |

|---|---|---|

| Git branch/commit/MR/CI | A/B | 幂等、受保护分支、旧 SHA、Webhook 重放 |

| WeKnora 查询/摄取/检索 | A/B | ACL、来源/版本、重复、索引失败和旧版本 |

| DSH 入口/插件 | B | 目标版本 UI/API 扩展、生命周期和身份传递 |

| Plugin/tool manifest and registry | B/C | 工具注册、权限、安装/启停、health、兼容性和回滚 |

| DSH Skill loader/profile | B | 固定 digest 装载、权限过滤、装载读回和回滚 |

| TeamAI CLI/repository/hooks/local injection | B/C | 目标版本 init/pull/push、MR、格式兼容、版本锁、灰度、安装读回、删除清理、回滚和内网/外网边界 |

| SkillHub/TeamAI distribution comparison | B/C | 固定版本、digest、profile、目标安装、审计、撤回和 fallback 的可替代性 |

| SkillHub 状态读取 | B | 版本、digest、owner 和状态是否可读 |

| SkillHub 上传/晋升 | C | API、审批、审计、回滚和 webhook；未确认则管理员操作 |

| MCP tools/list/call | A/B | profile 过滤、schema、ACL、审批、超时和取消 |

| OTel/观测出口 | B | DSH 事件出口、隐私策略和 run/job/asset 关联 |

| 多租户 Gateway | B | 身份、密钥、workspace 隔离和跨域拒绝 |

| 高风险 Agent 发布 | D（默认） | 人工 approval、服务端 policy、读回和回滚 |

3. 首先做的实验

V-01：Git provider contract

使用 fake provider 覆盖 branch、batch commit、MR、pipeline 和状态读取；再在隔离项目验证 protected main、expected base/head SHA、Webhook 签名、重复和乱序事件。

通过条件：重复请求不重复创建资源；所有动作能关联 actor、job、commit、MR 和 pipeline；旧 head SHA 合并被拒绝。

V-02：WeKnora 索引和检索

准备测试知识库和两个 workspace，上传带 canonical key、source commit、version、sensitivity 的脱敏文档，测试重复、ACL、hybrid search、旧版本、退役和索引失败。

通过条件：结果返回 document/version/source；跨 workspace 拒绝；索引失败不覆盖旧版本；`approved` 不被错误标成 `published`。

V-03：DSH 入口和 Skill loader

创建只读测试插件或 API bridge，验证入口注册、profile 传递、固定 Skill digest 装载、权限过滤、重启、升级、卸载、失败清理和回滚。

通过条件：实际装载版本可读回；Skill 声明的 effects 不能突破 profile/tool policy；失败则使用管理员安装或外部 Web/API 向导。

V-04：SkillHub/TeamAI 分发能力

固定目标 SkillHub、TeamAI、Git 服务、dsh 和 profile 版本，分别测试 package/仓库注册、metadata、`init`、变更分支 `push`、`pull`、MR/CI、Hook 生命周期、格式兼容、版本锁、beta/stable、目标安装、文件清单/installed revision 读回、删除清理、revoke、audit、Webhook/同步状态、断网恢复和回滚。

通过条件：未审核内容不能自动生效；至少一种路径能提供固定版本、digest、目标安装和实际读回；TeamAI/SkillHub 不可用时管理员 fallback 可运行；重复 pull/push 不产生重复资源；无 secret、敏感正文或生产凭据跨安全域同步；运行能关联实际安装 revision。TeamAI 的 Agent Manifest 复用另行验证，不得绕过 Skill/知识/权限门禁。

V-05：Skill contract and regression

用一个低风险 Skill 验证 input/output schema、缺字段、未知字段、超大输入、知识依赖缺失、effects 与 profile 冲突、golden cases、回归失败、digest 变化和旧版本回滚。

通过条件：契约或权限冲突阻止发布/装载；回归失败不能晋升 beta/stable；运行记录包含 Skill version/digest、profile 和知识引用。

V-06：MCP security contract

测试合法/非法/超大参数、无 token、跨 workspace、过期 token、无 approval、幂等、超时、断连和 cancellation；确认高风险工具默认不出现在普通 Agent 的列表中。

通过条件：拒绝有稳定错误码和审计；工具结果与真实 provider 状态一致；日志和 trace 无 token、Cookie 和敏感正文。

V-07：Plugin/tool 扩展能力

固定目标 DSH 版本和一个隔离外部系统，验证 tool manifest、input/output schema、profile 过滤、最小权限、Secret Manager 引用、安装/启用/禁用、health/readback、超时/重试/幂等、兼容性、审计和回滚。

通过条件： Plugin 未经权限授予不能出现在普通 profile；安装和实际工具注册可读回；provider unhealthy/unknown 时不能报告工具可用；失败可禁用并回到旧 digest。若能力未确认，只保留 fake provider 或人工安装，不阻塞知识 + Skill MVP。

4. 通用安全检查

| 检查 | 方法 | 必须结果 |

|---|---|---|

| Secret 泄露 | 扫描 Git、日志、trace、错误响应 | 无 token、Cookie、密钥 |

| 跨 workspace | 构造资源 ID 和 Webhook | 全部拒绝 |

| Webhook 重放 | 重复 event/旧 timestamp | 不重复执行 |

| 越权合并/晋升 | 普通用户调用 merge/promote | 拒绝并审计 |

| 权限冲突 | Skill effects 超出 profile | 发布和装载均拒绝 |

| Plugin/tool 权限 | 构造无 grant、过期 grant、跨 workspace 调用 | 全部拒绝并审计 |

| 参数注入 | 工具参数携带外部指令 | 只按 schema/策略处理 |

| 外部响应污染 | provider 返回恶意文本 | 不直接成为系统指令 |

| 任意文件上传 | 脚本、超大文件、路径穿越 | 拒绝或隔离 |

| 审计完整性 | 反查 actor/job/asset/version/digest | 每个写动作可追溯 |

5. 当前结论

第一版优先 fake provider、一个真实 Git/WeKnora 隔离环境和一个低风险 Skill 的非生产回放。SkillHub 自动发布、DSH UI/loader、Plugin/tool runtime、MCP 高风险工具和完整 Gateway 都必须先有实验结果，不能因为设计了 adapter 就视为已接通；但这些实现未验证不影响 Skill 管理作为产品核心能力继续交付。

02-DeepSeek-Bot能力评估

DeepSeek Bot 能力评估

> 本文是外部源码和能力验证材料，不是团队知识工程的核心架构。它只说明 DeepSeek Bot 能做什么、不能做什么，以及何时值得做 PoC。

1. 当前结论

基于已核验的 DeepSeek Bot 预览版本，DeepSeek Bot 是建立在 DeepSeek Harness 插件接口之上的多 Bot 组织、协作、长生命周期 Session 和本地记忆插件。

已确认的能力包括：Bot roster、角色化 Agent、Bot-to-Bot 消息、Group Chat、异步交接、Markdown Memory、Team Memory、定时任务、连接器和本地 usage ledger。

未确认它具备：组织知识索引和版本、Skill 注册/审核/分发、企业级 RBAC、多租户、统一审计、WeKnora/SkillHub 原生适配和 OTel/Phoenix/Langfuse 原生导出。

因此它只能作为 DSH 执行面之上的**可选协作层**，不能替代 Git、WeKnora、SkillHub、审批或企业控制面。

2. 能力边界

| DeepSeek Bot 能力 | 在本项目中的正确归属 | 结论 |

|---|---|---|

| Bot roster、Session、群聊和交接 | Agent 协作层 | 可候选 PoC |

| Bot/Team Memory | 运行时记忆/反馈候选 | 可用，但不能当正式知识 |

| 正式知识源文件和评审 | Git/CI | 不替代 |

| 知识索引、ACL、版本引用 | WeKnora | 需要外部适配 |

| Skill 注册、审核、digest 和晋升 | SkillHub + Git/CI | 未发现原生能力 |

| Plugin/tool 注册、安装、权限和健康 | Plugin registry/runtime + DSH profile | 需要外部适配和验证 |

| 工具权限和人工确认 | DSH profile/policy | 可复用，但需身份映射 |

| 统一 trace 和业务反馈 | 观测/反馈系统 | 需要适配器 |

3. Memory 的边界

Bot Memory 是本地运行时上下文，即使有自动 review，也不能证明事实经过领域责任人确认、跨场景验证或适合进入 WeKnora。Team Memory 的写权限也不等于正式知识审批。

Memory、群聊结论和 Bot-to-Bot 结果只能：

- 作为当前运行上下文；
- 生成反馈或候选记录；
- 由人确认后进入 Git MR；
- 经审核和索引确认后成为正式知识。

不得直接写入正式知识空间。

4. 推荐验证 PoC

选择一个低风险、只读、可回放任务，例如研究资料初筛和证据卡片整理：

```
Main Bot
  → Researcher Bot: 检索并列出引用
  → Reviewer Bot: 检查证据、范围和冲突
  → Editor Bot: 生成 Git MR 草稿
  → 领域 owner: 审核并合并
  → WeKnora: 索引批准版本
```

验收不看“群聊是否能完成”，而看：

- 每个 Bot 使用的 Skill 和知识版本是否可追溯；
- 结论能否区分事实、推断和未验证建议；
- Memory 是否严格停留在运行时；
- 失败和人工纠正能否生成候选；
- 是否真的减少交接和重复说明。

5. 进入条件和退出条件

只有在 P1/P2 稳定后，才做 Bot 协作 PoC。若需要多用户共享 roster、企业目录、集中任务队列、HA、限流、SLA、统一审计或服务端多租户，才重新评估服务端化；在此之前按本地 DSH 插件处理。

任何 Secret 都必须使用受控 Secret Manager，不能进入模型请求、工具结果、Git、Memory 或 trace。Bot、Room、Session、Exchange 和工具调用必须能关联到统一 run/correlation 链。Bot 不提供 Plugin registry、权限授予或外部系统健康的企业控制面。